

to get some understanding across the business about the different types of licences and implications you need to manage, and what tools you need to put in place,” Callinan says.

He points to the famous case of Tesla, where the company was forced to share the source code of its navigation system. Investors and companies need to evaluate and find if there are any risks in the code being used.

Licences are not ambiguous:

Mukundaraj says it is very difficult to explain licence ambiguity to your development team, whether it is internal or external. It's even more tedious to figure out whether your vendors have also complied with the different licences. Licences get pretty ambiguous within selected categories at times, and you don't know whether you are compliant with them or not.

Certain licences can be used only for educational institutions and not for a commercial organisation. But sometimes developers think it is fine to use them for their proof-of-concept within the company and purchase a commercial licence later.

“You are just not allowed to do that, because the licence clearly says that if you want to use the free version, you either have to be an education society or a non-profit organisation. Otherwise, you cannot use it even for proof-of-concept or proof-of-experiment. Stay in touch with your lawyers, so that you don't make your own choice of licences,” he says.

“Always include security in your checklist as resolving any breaches will cost you more,” Callinan warns.

Also look for the people who are enforcing open source licences. Traditionally, this would be the community's free software foundation or a freedom law centre. But now it turns out that competitors, individuals, developers and corporates are enforcing these. For example, in the case of CoKinetic Systems Corporation versus Panasonic, the

former claimed damages for a hundred billion US dollars and Panasonic was forced to comply.

“If we find text in a company's code without a commercial licence, they may not be sharing their source code in obligation to some GPL licence. I would look at that as a risky investment. OpenChain can be used to check for mergers and acquisitions. Benchmark a target company, audit its maturity with respect to managing issues, and then you can decide if it is a risk investment or not,” says Callinan.

Check out these tools and tips

There are great projects like SPDX, which is an ISO 5962 standard that can be used by companies. Open source tools and projects should be used for compliance and detection of libraries, snippets, licensing and obligations.

Say, for example, if you look at codes on GitHub, the licence information is never consistent. Some people use copyright statements, Apache licence, and so on. This makes it hard to manage all those different licences coming into your code. In such cases, it's best to look for an SPDX software package or Data Exchange kind of projects. Callinan says, “The idea of SPDX is to drive consistency of documentation of the licences posted, both in human and computer readable formats. So when you consume software, you can easily identify what licences are in the code. And when you ship your software, you can easily communicate about those licences, which makes it easier to manage the software.”

Narayanam suggests FOSSology be used to understand licensing copyright compatibility. He says, “This binary scan tool will help to find out all the binaries and the corresponding source code that can be risky. And with respect to security concerns, fuzzing angle, peach fuzzer

or a scan burp suit can help. FindBugs and Sonarqube can support quality. So, if some project is hosted on GitHub, we can incorporate a lot of tools if it is completely open source.”

Commercial open source software can be used outside the scope of the open source licence. Avci says there are cases where a developer uses one version of a software in a project that comes with an Apache licence. When this software is upgraded to a new version, the developer assumes the licence has been complied with already. But this may not be the case. The compliance check is ongoing. “An open source project like iText has had three major releases in the past and the latest has a new AGPL licence model. A user compliant with the earlier versions just cannot overlook the new licence,” says Avci.

Since it is not easy for small organisations and enterprises to consult lawyers every time, Avci recommends a few simple checks to avoid risking your business. In large enterprises, open source software is often implemented with the help of external software providers. These enterprises may not be aware of what is in the software they receive from a third party software vendor. So it is a good practice to check the software bill of materials (SBOM) as it will tell you if the software given to you is compliant or non-compliant. This is a small step to start with.

Second, developers assume the licence document to be too legal and tend not to read it. But remember, all the initial open source licence documents were formulated by the technical people and not lawyers. “Just take the responsibility to go through the documentation as it may be too technical for lawyers,” Avci adds.

Mukundaraj says that lawyers help to enhance protection. “As developers, read documentation with a technical perspective. If you feel it does not satisfy your project, then go to a lawyer. If you feel unsatisfied, push it through